

CVEs más relevantes de la semana

Del 28/07/2026 al 04/08/2026

Porque el primer paso para defender es conocer las amenazas.



CVE-2026-16184

Descripción: IBM WebSphere Application Server 9.0, and 8.5 could allow a remote attacker to bypass authentication by sending a crafted unauthenticated request.

CVSS: 7.0 (HIGH)

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:L/A:H

Tipo: CWE-862

Tecnología: No especificado

Publicado el: 2026-07-28



CVE-2026-58163

Descripción: Apache Traffic Server mishandles on-disk cache fields and object lifetimes, corrupting state or crashing.

This issue affects Apache Traffic Server: from 8.0.0 through 8.1.9, from 9.0.0 through 9.2.14, from 10.0.0 through 10.1.3.

Users are recommended to upgrade to version 9.2.15 or 10.1.4, which fix the issue.

CVSS: 7.5 (HIGH)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:N

Tipo: CWE-502

Tecnología: No especificado

Publicado el: 2026-07-29



CVE-2026-58177

Descripción: The Apache Traffic Server Cripts framework has out-of-bounds writes, path traversal, and use-after-free errors.

This issue affects Apache Traffic Server: from 10.0.0 through 10.1.3.

Users are recommended to upgrade to version 10.1.4, which fix the issue.

CVSS: 8.1 (HIGH)

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:C/C:L/I:L/A:H

Tipo: CWE-787

Tecnología: No especificado

Publicado el: 2026-07-29



CVE-2026-58179

Descripción: The Apache Traffic Server regex_remap plugin overflows the stack and integers from substitution input.

This issue affects Apache Traffic Server: from 8.0.0 through 8.1.9, from 9.0.0 through 9.2.14, from 10.0.0 through 10.1.3.

Users are recommended to upgrade to version 9.2.15 or 10.1.4, which fix the issue.

CVSS: 8.1 (HIGH)

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-121

Tecnología: No especificado

Publicado el: 2026-07-29



CVE-2026-58185

Descripción: The Apache Traffic Server intercept plugin has a use-after-free.

This issue affects Apache Traffic Server: from 8.0.0 through 8.1.9, from 9.0.0 through 9.2.14, from 10.0.0 through 10.1.3.

Users are recommended to upgrade to version 9.2.15 or 10.1.4, which fix the issue.

CVSS: 5.9 (MEDIUM)

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:N/I:N/A:H

Tipo: CWE-416

Tecnología: No especificado

Publicado el: 2026-07-29



CVE-2026-13697

Descripción: undici's cache interceptor mishandles malformed Cache-Control private directives. In undici 7.0.0 up to before 7.29.0 and 8.0.0 up to before 8.9.0, a response carrying a degenerate qualified private directive, such as private set to an empty value, can be stored in the default shared cache and later served to a different caller with the same cache key, disclosing private response bodies and hea...

CVSS: 7.4 (HIGH)

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:N/A:H

Tipo: CWE-200

Tecnología: No especificado

Publicado el: 2026-07-29



CVE-2026-14529

Descripción: IBM WebSphere Application Server 9.0, and 8.5 and IBM WebSphere Application Server - Liberty 17.0.0.3 through 26.0.0.8 traditional is vulnerable to server-side request forgery (SSRF) when the SIP container feature (sipServlet-1.1) is enabled.

CVSS: 9.4 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:L

Tipo: CWE-306

Tecnología: No especificado

Publicado el: 2026-07-29



CVE-2026-4978

Descripción: Improper neutralization of special elements used in an SQL command ('SQL injection') vulnerability in UMAI Vision Traffic Analysis System allows SQL Injection.

This issue affects Traffic Analysis System: from 30 before 34.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-89

Tecnología: No especificado

Publicado el: 2026-07-30



CVE-2026-12118

Descripción: IBM webMethods Integration (on prem) 10.15, 10.11 could allow an unauthenticated remote attacker to execute arbitrary code on the system due to the deserialization of untrusted data.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-502

Tecnología: No especificado

Publicado el: 2026-07-30



CVE-2026-67208

Descripción: Juggle through 1.6.0 contains a remote code execution vulnerability that allows unauthenticated remote attackers to execute arbitrary OS commands by connecting to the exposed H2 database web console using default shipped credentials. Attackers can access the unprotected /h2-console endpoint, authenticate with default credentials, and leverage the H2 CREATE ALIAS Runtime.exec() technique to exec...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-306

Tecnología: No especificado

Publicado el: 2026-07-30



CVE-2026-18602

Descripción: A vulnerability was determined in GL.iNet GL-MT3000 up to 4.4.5. Affected is the function ovpn-client.get_recommend_config of the file /cgi-bin/glc of the component ovpn-client.so Native Plugin. Executing a manipulation of the argument Hostname can lead to command injection. The attack can be executed remotely. The exploit has been publicly disclosed and may be utilized. The vendor was contacte...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-74

Tecnología: No especificado

Publicado el: 2026-08-03



CVE-2026-39932

Descripción: OpenEMR through 8.2.0 contains a remote code execution vulnerability in the document category tree component (library/classes/Tree.class.php) that allows authenticated administrators to execute arbitrary operating system commands by injecting PHP payloads into the categories database table. Attackers can chain arbitrary SQL execution to alter the id column type to VARCHAR and insert a malicious...

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-95

Tecnología: No especificado

Publicado el: 2026-08-03



CVE-2026-41452

Descripción: Krayin CRM 2.2.4 contains a missing authentication vulnerability in the installer middleware that allows unauthenticated remote attackers to overwrite the primary administrator account by sending a crafted HTTP POST request with the X-Requested-With: XMLHttpRequest header to bypass the CanInstall middleware redirect check. Attackers can supply arbitrary name, email, and password values to the a...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-306

Tecnología: No especificado

Publicado el: 2026-08-03



CVE-2026-18614

Descripción: A vulnerability was found in GL-iNet GL-MT3000 up to 4.4.5. Impacted is the function `s2s.enable_echo_server` of the file `/cgi-bin/glc` of the component `s2s.so` Native Plugin. Performing a manipulation of the argument `port` results in command injection. The attack may be initiated remotely. The exploit has been made public and could be used. The vendor was contacted early about this disclosure and c...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-74

Tecnología: No especificado

Publicado el: 2026-08-03



CVE-2026-18616

Descripción: A vulnerability was identified in GL-iNet GL-MT3000 up to 4.4.5. The impacted element is the function `server.set_peer` of the file `/cgi-bin/glc` of the component `wg-server.so` Native Plugin. The manipulation of the argument `public_key` leads to command injection. Remote exploitation of the attack is possible. The exploit is publicly available and might be used. The vendor was contacted early about ...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-74

Tecnología: No especificado

Publicado el: 2026-08-03



CVE-2026-48330

Descripción: Adobe Campaign Classic (ACC) is affected by an Improper Neutralization of Special Elements used in an SQL Command ('SQL Injection') vulnerability that could result in arbitrary code execution in the context of the current user. An attacker could exploit this vulnerability to execute arbitrary SQL commands, potentially gaining elevated access or control over the application. Exploitation of this...

CVSS: 10.0 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-89

Tecnología: No especificado

Publicado el: 2026-08-03



CVE-2026-61515

Descripción: Puwell IP Camera firmware versions 2.x through 4.x contains an unauthenticated command injection vulnerability that allows remote attackers to execute arbitrary operating system commands by sending a crafted JSON payload to the DebugShell interface exposed on TCP port 34567. Attackers can exploit the lack of authentication and input sanitization in the binary protocol service to pass arbitrary ...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-912

Tecnología: No especificado

Publicado el: 2026-08-04



CVE-2026-69098

Descripción: kotaemon through 0.12.0 contains an insecure deserialization vulnerability in the check_connection endpoint that allows unauthenticated attackers to instantiate arbitrary Python classes by supplying crafted YAML/JSON input with a __type__ field. Attackers can exploit this to override the __type__ field with subprocess.check_output and arbitrary arguments, achieving remote code execution with ap...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-502

Tecnología: No especificado

Publicado el: 2026-08-04



Resumen del Reporte

CVEs analizados: 18

Promedio CVSS: 8.93

Fuente: nvd.nist.gov

Nos vemos la próxima semana. Hack the Cat ☹

